ICC-003 • THE BUGS • CyberCore Solution •

PURPLE TEAM

Security Assessment Report

CLIENT	NETWORK	DOMAIN
CyberCore Solution	10.0.0.0/24	corp.org
DATE	TYPE	
02/27/2026	Purple Team	

RED TEAM (BLACK BOX)

BLUE TEAM (SOC)

Team members

Brandon

Red Team Operator

Exploitation & Privilege Escalation

Rodrigo

Red Team Operator

Reconnaissance & Initial Access

Miguel

Red Team Operator

Exploitation & Privilege Escalation

Maria

Blue Team Analyst

SIEM, Packet Capture & Reporting

Red Team - Black Box Engagement

CONTEXT

Black-box engagement — zero prior knowledge of the target infrastructure (10.0.0.0/24, corp.org). The team commenced with no credentials, no documentation, and no internal network access.

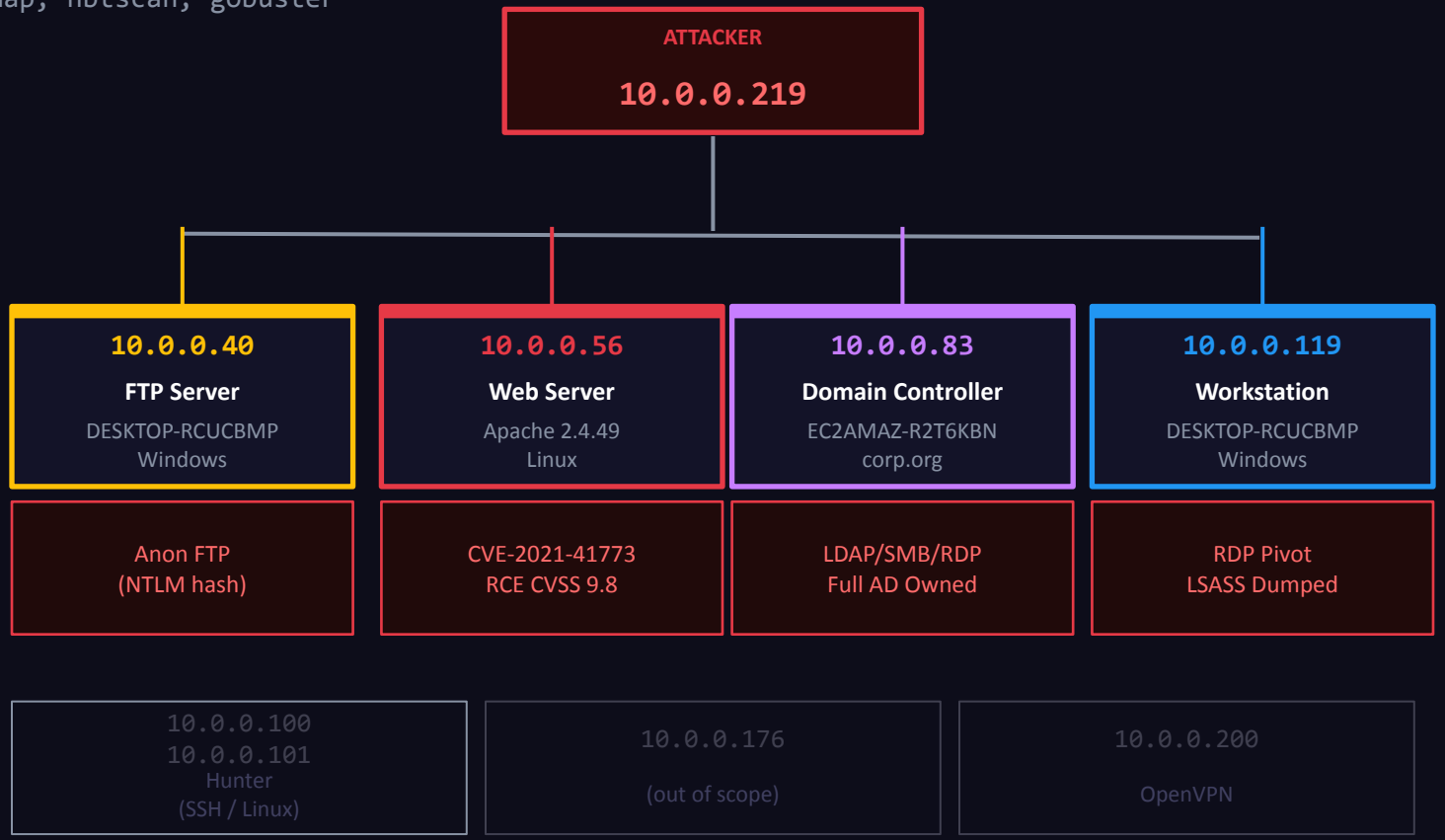
OBJECTIVES

- Enumerate active hosts and exposed network services
- Exploit identified vulnerabilities without prior knowledge
- Compromise endpoints and escalate local privileges
- Achieve Domain Administrator (DA) control on corp.org
- Document the complete attack path end-to-end

RED TEAM • RECONNAISSANCE

Network Topology

Tools: nmap, nbtscan, gobuster



Vulnerability Matrix

SEV	HOST	VULNERABILITY	CVE / CWE	CVSS	STATUS
CRITICAL	10.0.0.56	Apache Path Traversal + RCE Unauthenticated Remote Code Execution	CVE-2021-41773 CVE-2021-42013 / CWE-22	9.8	Exploited
HIGH	10.0.0.40 / .119	Anonymous FTP → NTLM Hash Exposure Hash cracked → Domain Admin	CWE-287 / CWE-798 CWE-200	8.1	Exploited
HIGH	10.0.0.40	Anonymous FTP Enabled FileZilla FTP 1.8.2 — no auth required	CWE-287	7.5	Confirmed
MEDIUM	10.0.0.56	Cross-Site Tracing (XST) HTTP TRACE method enabled	CWE-16	5.3	Confirmed
MEDIUM	10.0.0.56	MySQL Service Exposed Host-based restriction only (no strong auth)	CWE-284	5.0	Confirmed

CVE-2021-41773 / CVE-2021-42013

Apache 2.4.49 — Path Traversal + Remote Code Execution | Host: 10.0.0.56 | CVSS 9.8 CRITICAL

HOST	CVSS SCORE	CWE	AUTH REQUIRED
10.0.0.56	9.8	CWE-22 Path Traversal	NONE (Unauthenticated)

HOW IT WORKS

PATH TRAVERSAL

URL-encoded sequences (%2e%2e) bypass Apache's path sanitisation, allowing traversal outside the webroot to access arbitrary filesystem locations.

CGI + SHELL EXECUTION

A POST request to /cgi-bin/../bin/sh with a data payload executes arbitrary OS commands via mod_cgi, resulting in unauthenticated RCE.

NO AUTHENTICATION REQUIRED

The exploit functions on a default Apache 2.4.49 install with mod_cgi enabled. Zero credentials are required to achieve code execution.

ROOT-LEVEL IMPACT

Commands execute as the daemon user, yielding full web server control and enabling lateral movement across the internal network.

PROOF OF CONCEPT — EXPLOIT OUTPUT

```
root@kali:~# python3 exploit.py 10.0.0.56 80 rce "id"
[i] Host appears to be vulnerable.
[*] Working Payload: http://10.0.0.56:80/cgi-bin/
    /.%2e/%2e%2e/%2e%2e/%2e%2e/bin/sh

$ id
uid=1(daemon) gid=1(daemon) groups=1(daemon)

$ pwd
/usr/bin

$ whoami
daemon

$ hostname
ip-10-0-0-56

[+] RCE confirmed. Shell spawned as daemon.
[+] Lateral movement possible — no further auth required.
```

kali

1 2 3 4

23:32

ubuntu@ip-10-0-0-219: ~

Session Actions Edit View Help

```
ubuntu@ip-10-0-0-219:~$
```

5-Step Attack Chain — Full Domain Compromise

01

Anon FTP Exposure

FileZilla FTP 1.8.2
anonymous login allowed
Host: 10.0.0.40

MITRE
Initial Access

02

NTLM Hash Cracked

SHA-NTLMv2 hash cracked
via online lookup tool
(< 60 seconds)

MITRE
Credential
Access

03

RDP — Workstation

Authenticated via RDP
as local Admin
Host: 10.0.0.119

MITRE
Lateral
Movement

04

LSASS Memory Dump

rundll32 comsvcs.dll
56 MB dump exfiltrated
10.0.0.119 → .219

MITRE
Credential
Access

05

Domain Controller

CORP\Administrator creds
DA access via FreeRDP
Host: 10.0.0.83

MITRE
Privilege
Escalation

ATTACK TIMELINE

- Feb 13 - RDP Auth
- Feb 13 - LSASS Dump
- Feb 13 - DC Compromised
- Feb 23 - Logs Cleared (1102)

Key Findings

4	1	5	0
Hosts Compromised	Critical CVE (CVSS 9.8)	Attack Steps to DA	Days to Full AD Control*

ROOT CAUSES

- Anonymous FTP exposed NTLM hash — no authentication required
- Weak admin password (q1*******) cracked offline in under 60 seconds
- No LSASS protection — SeDebugPrivilege enabled on workstations
- Apache 2.4.49 unpatched — CVE-2021-41773 (CVSS 9.8) exploitable
- No network segmentation — DC directly reachable from workstations

BUSINESS RISK

- Ransomware Deployment Risk
- Regulatory & Compliance Exposure
- All Domain Credentials Compromised
- Operational Disruption Potential
- Evidence Destruction Detected (Event 1102)

Blue Team - SOC Defensive Analysis

CONTEXT

The Blue Team (SOC) monitored the 10.0.0.0/24 network and the corp.org Active Directory domain using Elastic SIEM, Wireshark, and Windows Event Viewer for the duration of the purple team exercise.

Elastic SIEM

Log ingestion & centralised alerting (Elastic 7.0+ / Shield)

Wireshark

Packet capture & network traffic analysis FTP / SMB / HTTP

Event Viewer

Windows security audit log monitoring Security & System logs

OBJECTIVES

- Detect reconnaissance & exposed service enumeration
- Identify & triage exploitation attempts in real time
- Prevent privilege escalation and lateral movement
- Document detections, gaps, and response actions

DETECTION COVERAGE

7/7

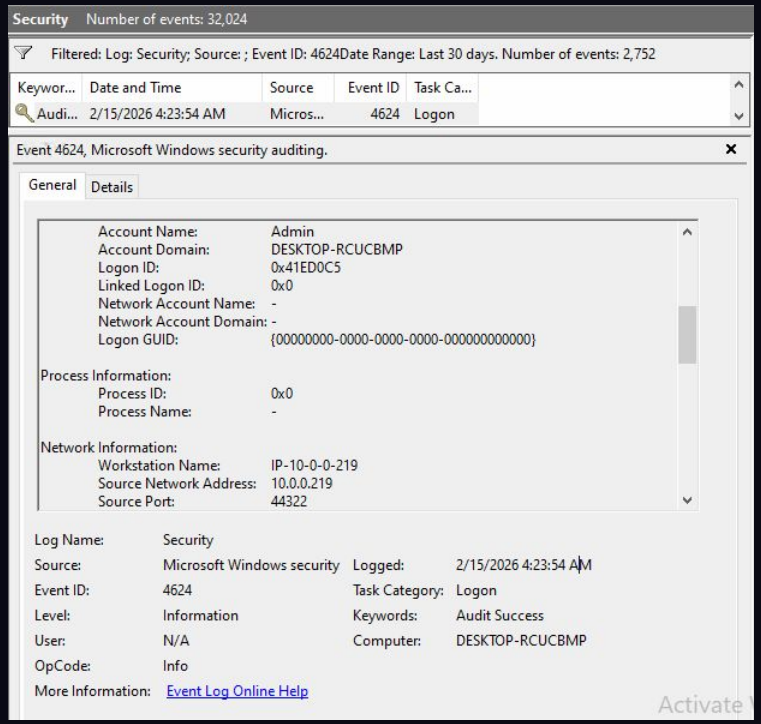
MITRE Techniques Detected

- ✓ Active Scanning (T1595)
- ✓ Valid Accounts / Anon FTP (T1078)
- ✓ Exploit Public App (T1190)
- ✓ Remote Services / RDP (T1021)
- ✓ LSASS Memory Dump (T1003)
- ✓ Indicator Removal (T1070)
- ✓ Domain Policy Modification (T1484)

Detection Log

DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	4624 Type 3	Successful NTLMv2 network logon Admin — source 10.0.0.219:44322	Feb 15 04:23:54	DESKTOP-RCUCBMP Event Viewer Security
✓	FTP 1110	Anon FTP — RETR rdp-settings.txt 14 packets — C:\ftp-files\	Feb 24 05:36:44 UTC 10.0.0.219 → 10.0.0.40:21	Wireshark Packet Capture
✓	1149 RDP	RDP authentication success — User: Admin Source: 10.0.0.219	Feb 13 08:59:23 DESKTOP-RCUCBMP	TermSvc RDP Log
✓	SMB LSASS	LSASS dump transfer over SMB 10.0.0.119 → .40 → .219 (multi-hop)	Feb 13 ~14:42 SMB port 445	Wireshark Packets
✓	1102 Audit	Security Log CLEARED — Destructive action CORP\Administrator on Domain Controller	Feb 23 16:52:47 EC2AMAZ-R2T6KBN	Event Viewer Security Log

DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	4624 Type 3	Successful NTLMv2 network logon Admin — source 10.0.0.219:44322	Feb 15 04:23:54	DESKTOP-RCUCBMP Event Viewer Security



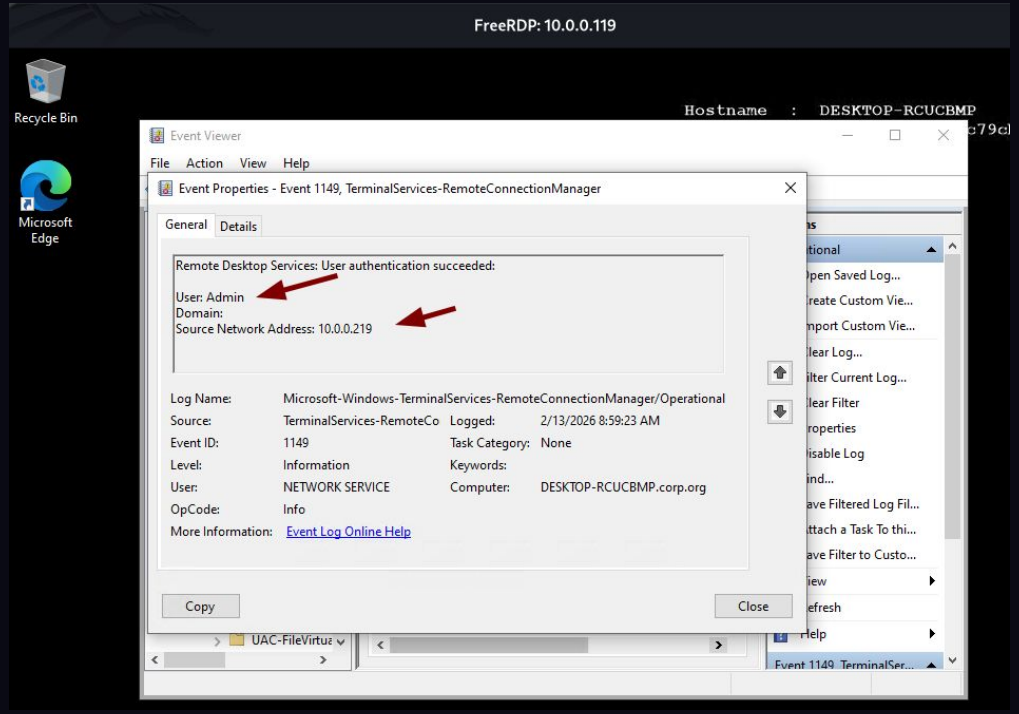
DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	FTP 1110	Anon FTP — RETR rdp-settings.txt 14 packets — C:\ftp-files\	Feb 24 05:36:44 UTC 10.0.0.219 → 10.0.0.40:21	Wireshark Packet Capture

ftp

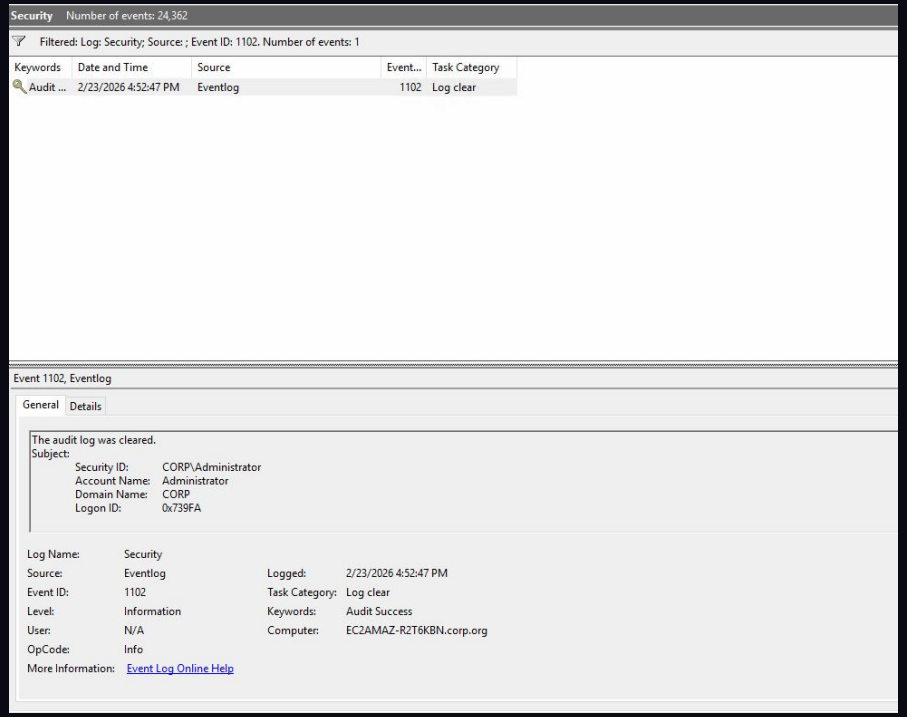
No.	Time	Source	Destination	Protocol	Length	Info
156	14.110453	10.0.0.219	10.0.0.40	FTP	120	Request: USER anonymous
219	18.287178	10.0.0.219	10.0.0.40	FTP	120	Request: PASS anonymous
221	18.288226	10.0.0.219	10.0.0.40	FTP	110	Request: SYST
222	18.288519	10.0.0.219	10.0.0.40	FTP	110	Request: FEAT
243	20.600846	10.0.0.219	10.0.0.40	FTP	110	Request: EPSV
245	20.601936	10.0.0.219	10.0.0.40	FTP	110	Request: LIST
278	24.084899	10.0.0.219	10.0.0.40	FTP	110	Request: EPSV
279	24.086076	10.0.0.219	10.0.0.40	FTP	110	Request: NLST
291	25.134136	10.0.0.219	10.0.0.40	FTP	112	Request: TYPE I
292	25.134744	10.0.0.219	10.0.0.40	FTP	127	Request: SIZE rdp-settings.txt
293	25.135457	10.0.0.219	10.0.0.40	FTP	110	Request: EPSV
294	25.136447	10.0.0.219	10.0.0.40	FTP	127	Request: RETR rdp-settings.txt
300	25.139620	10.0.0.219	10.0.0.40	FTP	127	Request: MDTM rdp-settings.txt
334	27.994649	10.0.0.219	10.0.0.40	FTP	110	Request: QUIT

2/24/2026 5:36:44 ...	FTP Session 1110 10.0....	Command	USER anonymous
2/24/2026 5:36:44 ...	File-based Authentica...	Trace	Invoked authenticate(()) on worker 0x2604f03eb20, with available methods = []
2/24/2026 5:36:44 ...	File-based Authentica...	Trace	Authentication for user 'anonymous' not complete. Remaning methods: []
2/24/2026 5:36:44 ...	File-based Authentica...	Trace	Worker 0x2604f03eb20 created new operation 0x2604e8267c0, with shared_user = 0x0, methods = [], error = 0
2/24/2026 5:36:44 ...	FTP Session 1110 10.0....	Response	331 Please, specify the password.
2/24/2026 5:36:48 ...	FTP Session 1110 10.0....	Command	PASS ****
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	Invoked authenticate((password)) on worker 0x2604f03eb20, with available methods = []
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	Authenticating user 'anonymous'. Methods requested: (password). Available methods: [].
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	Authentication for user 'anonymous' is complete.
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	Effective mount points:
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	> "/" -> "C:\ftp-files"
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	impersonation_token: { username: "", home: "" }
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	Worker 0x2604f03eb20 created new operation 0x2604e826270, with shared_user = 0x2604e82d0c0, methods = [], erro
2/24/2026 5:36:48 ...	File-based Authentica...	Trace	operation 0x2604e826270 stop() erasing worker 0x2604f03eb20
2/24/2026 5:36:48 ...	FTP Session 1110 10.0....	Response	230 Login successful.

DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	1149 RDP	RDP authentication success — User: Admin Source: 10.0.0.219	Feb 13 08:59:23 DESKTOP-RCUCBMP	TermSvc RDP Log



DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	1102 Audit	Security Log CLEARED — Destructive action CORP\Administrator on Domain Controller	Feb 23 16:52:47 EC2AMAZ-R2T6KBN	Event Viewer Security Log



DET.	EVENT	DESCRIPTION	TIMESTAMP / SOURCE	LOG SOURCE
✓	SMB LSASS	LSASS dump transfer over SMB 10.0.0.119 → .40 → .219 (multi-hop)	Feb 13 ~14:42 SMB port 445	Wireshark Packets

609	25.877445	10.0.0.119	10.0.0.40	NBSS	284	Session message
610	25.877476	10.0.0.101	10.0.0.40	ICMP	312	Destination unreachable (Port unreachable)
611	25.877636	10.0.0.171	10.0.0.40	ICMP	362	Destination unreachable (Port unreachable)
612	25.877805	10.0.0.40	10.0.0.119	SMB2	348	Create Response File:
613	25.878153	10.0.0.119	10.0.0.40	NBSS	196	Session message
614	25.878377	10.0.0.40	10.0.0.119	SMB2	232	Close Response
615	25.879206	10.0.0.119	10.0.0.40	NBSS	464	Session message
616	25.879848	10.0.0.40	10.0.0.119	SMB2	460	Create Response File: [unknown]
617	25.880128	10.0.0.119	10.0.0.40	NBSS	325	Session message
618	25.880279	10.0.0.40	10.0.0.119	SMB2	300	GetInfo Response;GetInfo Response
619	25.880621	10.0.0.119	10.0.0.40	TCP	212	50962 → 445 [PSH, ACK] Seq=182 Ack=245 Win=8195 Len=108
620	25.880672	10.0.0.40	10.0.0.119	SMB2	174	SetInfo Response
621	25.881340	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=94 Ack=129 Win=8210 Len=1460
622	25.881340	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=1554 Ack=129 Win=8210 Len=1460
623	25.881340	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=3014 Ack=129 Win=8210 Len=1460
624	25.881340	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=4474 Ack=129 Win=8210 Len=1460
625	25.881422	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=5934 Ack=129 Win=8210 Len=1460
626	25.881423	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=7394 Ack=129 Win=8210 Len=1460
627	25.881423	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=8854 Ack=129 Win=8210 Len=1460
628	25.881423	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=10314 Ack=129 Win=8210 Len=1460
629	25.881423	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=11774 Ack=129 Win=8210 Len=1460
630	25.881423	10.0.0.119	10.0.0.40	TCP	1564	50959 → 445 [ACK] Seq=13234 Ack=129 Win=8210 Len=1460

No.	Time	Source	Destination	Protocol	Length	Info
479	40.639514	10.0.0.219	10.0.0.40	TCP	124	41708 → 445 [SYN] Seq=0 Win=62727 Len=0 MSS=8961 SACK_PERM TSval=4
480	40.639586	10.0.0.219	10.0.0.40	TCP	104	41708 → 445 [ACK] Seq=1 Ack=1 Win=62848 Len=0
481	40.639718	10.0.0.219	10.0.0.40	SMB2	334	Negotiate Protocol Request
482	40.641868	10.0.0.219	10.0.0.40	TCP	104	41708 → 445 [ACK] Seq=231 Ack=513 Win=62336 Len=0
483	40.646655	10.0.0.219	10.0.0.40	SMB2	270	Session Setup Request, NTLMSSP_NEGOTIATE
484	40.651047	10.0.0.219	10.0.0.40	SMB2	734	Session Setup Request, NTLMSSP_AUTH, User: DESKTOP-RCUCBMP\Admin
485	40.679292	10.0.0.219	10.0.0.40	SMB2	212	Tree Connect Request Tree: \\10.0.0.40\IPC$
486	40.687430	10.0.0.219	10.0.0.40	SMB2	262	Ioctl Request FSCTL_DFS_GET_REFERRALS, File: \10.0.0.40\dump
487	40.687789	10.0.0.219	10.0.0.40	SMB2	176	Tree Disconnect Request
488	40.688679	10.0.0.219	10.0.0.40	SMB2	212	Tree Connect Request Tree: \\10.0.0.40\dump
489	40.729903	10.0.0.219	10.0.0.40	TCP	104	41708 → 445 [ACK] Seq=1473 Ack=1281 Win=62080 Len=0
490	40.790832	10.0.0.219	10.0.0.40	SMB2	176	KeepAlive Request

MITRE ATT&CK Technique Coverage

DET.	TECHNIQUE ID	TECHNIQUE	TACTIC	EVIDENCE
DETECTED	T1595	Active Scanning	Reconnaissance	nmap -sn / -A -sV / --script vuln on 10.0.0.0/24
DETECTED	T1078	Valid Accounts (Anon FTP)	Initial Access	Anonymous FTP login → rdp-settings.txt → Event 4624
DETECTED	T1190	Exploit Public App (Apache RCE)	Initial Access	CVE-2021-41773 exploit → daemon shell on 10.0.0.56
DETECTED	T1021.001	Remote Services (RDP)	Lateral Movement	Event 1149 — RDP from .219 to .119 & .83
DETECTED	T1070.001	Indicator Removal (Log Clear)	Defense Evasion	Event 1102 — CORP\Administrator cleared Security log on DC
DETECTED	T1484	Domain Policy Modification	Impact	Full Domain Admin on 10.0.0.83 — FreeRDP session confirmed

Remediation Roadmap

IMMEDIATE
0 – 7 Days

10.0.0.56 / NIST SI-2

Patch Apache to v2.4.51+

Critical Impact

10.0.0.40 / NIST AC-3

Disable anonymous FTP on FileZilla

High Impact

All hosts / NIST IA-5

Reset all exposed credentials (Admin, CORP\Admin, john)

Critical Impact

DC / WS / NIST AC-17

Restrict RDP — enforce VPN + NLA

High Impact

SHORT TERM
7 – 30 Days

All Windows Hosts

Deploy Sysmon - closes LSASS detection blind spot

Critical Impact

All Windows Hosts

Deploy LAPS - eliminates shared local admin passwords

High Impact

All hosts

Define & enforce patch management SLA

High Impact

LONG TERM
30 – 90 Days

Network

Implement segmentation — isolate DC from workstations and DMZ

Critical Impact

SIEM

Centralise logging — add alerting rules for T1003, T1070, T1078

High Impact

All hosts

Monthly vulnerability scanning with formal patch SLA

Medium Impact

10.0.0.56

Harden MySQL — remove host-based access restrictions

Low Impact

What Happened & What To Do

WHAT HAPPENED

Misconfigured FTP service

An FTP server permitted anonymous access with no credentials, exposing an admin NTLM credential file.

Weak password cracked instantly

The NTLM hash was reversed to a simple keyboard pattern (q1*******) in under 60 seconds using an online lookup tool.

Full network access gained

Using the recovered password, the attacker authenticated via RDP, then dumped all in-memory credentials via LSASS.

Domain Administrator obtained

With domain credentials, the attacker gained complete control of corp.org, all systems, users, and policies.

Evidence destroyed

Windows Security audit logs were deleted on the DC to cover tracks, detected via Event ID 1102.

WHAT TO DO

URGENT — Patch Apache, disable anonymous FTP, reset all domain credentials.

URGENT — Conduct forensic review of all systems assume all credentials are compromised until verified otherwise.

HIGH — Deploy Sysmon on all Windows endpoints to detect future LSASS dump attempts .

HIGH — Restrict RDP and SMB to admin subnets via VPN only , no direct exposure from the LAN.

MEDIUM — Isolate the Domain Controller via network segmentation, it must not be directly reachable from workstations.

Next Steps — Call to Action

01 THIS WEEK

- Patch Apache 2.4.49 → 2.4.51+
- Disable anonymous FTP on 10.0.0.40
- Reset all exposed credentials (Admin, CORP\Administrator, john)
- Block external RDP — enforce VPN + NLA

02 THIS MONTH

- Deploy Sysmon on all Windows hosts (close LSASS detection blind spot)
- Deploy LAPS for automated local admin password rotation
- Patch OpenSSH CVE-2024-6387 (.23, .100, .101)
- Define and enforce patch management SLA

03 THIS QUARTER

- Implement network segmentation Isolate DC from workstations
- Centralise logging with SIEM alerting rules (T1003, T1070, T1078)
- Conduct follow-up penetration test to verify remediation effectiveness
- Security awareness training for all staff

Q&A